

Mapeo de objetivos/preguntas GQM a requisitos normativos y marcos

Métrica	Objetivo GQM (resumen)	Preguntas clave asociadas	RGPD / AEPD	NIST AI RMF / Perfil Agentic	ENISA / otros
UAR	Reducir acciones inseguras de agentes en sistemas críticos.	¿Con qué frecuencia los agentes violan políticas? ¿En qué contextos ocurre?	Principios de integridad, confidencialidad y accountability; EIPD para tratamientos de alto riesgo.	Funciones Mapear y Medir: evaluación de riesgos de comportamiento de agentes.	Buenas prácticas de ciberseguridad de IA, pruebas y validación continua.
PAR	Asegurar que el comportamiento de los agentes se ajusta a políticas internas y normativas.	¿Qué porcentaje de acciones cumple las políticas?	Cumplimiento de políticas internas y de tratamiento de datos; guía AEPD Agentic.	Gobernar: políticas, controles y supervisión de agentes.	Controles de cumplimiento y auditoría continua.
PED	Limitar la capacidad de los agentes para escalar privilegios más allá de su rol.	¿Cuántos niveles de privilegio puede atravesar el agente?	Principio de minimización de datos y acceso; seguridad del tratamiento.	Medidas técnicas para limitar capacidades y accesos de agentes.	Gestión de identidades, accesos y privilegios en sistemas IA.
OORAR	Mantener a los agentes dentro de su ámbito funcional definido.	¿Con qué frecuencia actúan fuera de rol?	Limitación de finalidades y usos; control de funciones automatizadas.	Gobernar y Medir: definición de alcance y límites de los agentes.	Definición de perfiles de uso y control de funciones.
RRS	Controlar el riesgo asociado a las fuentes de datos de las que los agentes recuperan información.	¿Qué riesgo presentan las fuentes usadas por el agente?	Calidad y fiabilidad de fuentes; minimización y exactitud.	Evaluación de datos de entrenamiento y fuentes de contexto.	Clasificación y protección de fuentes de datos en IA.

CES	Vincular vulnerabilidad es Agentic con impacto económico estimado.	¿Cuál es el coste potencial de explotación?	Evaluaciones de impacto económico de brechas.	Integración de métricas de riesgo en la gestión corporativa.	Análisis de riesgo financiero y aseguramiento .
TTC	Reducir el tiempo de contención de incidentes Agentic.	¿Cuánto tardamos en contenerlos?	Obligación de notificación y gestión rápida de incidentes.	Gestionar: respuesta a incidentes.	Buenas prácticas de respuesta en ENISA Threat Landscape.
Alert Triage Automation Rate	Medir el grado de automatización en triage de alertas.	¿Qué porcentaje de alertas se triagea con agentes?	Uso responsable de automatización en decisiones.	Integración de agentes en SOC.	Prácticas de SOC con IA.
MTTT	Mejorar la eficiencia en la clasificación de alertas.	¿Cuánto tiempo dedicamos a triage?	Eficiencia operativa para proteger datos.	Mejora de procesos operativos con IA.	Métricas clásicas adaptadas a SOC Agentic.
False Positive Reduction Rate	Reducir la carga de falsos positivos para SOC.	¿Qué reducción logramos tras introducir IA?	Optimizaciones que reducen exposición y fatiga del analista.	Evaluación de beneficios operativos de IA.	Indicadores de calidad de detección.